



INTEGRACIÓN OPENPAY

Pruebas en el ambiente sandbox y hallazgos corregidos

Suscripción de vigilancia fiscal — www.yaakob.com

Para el equipo de validación de Openpay

24 de agosto de 2026

Este documento reporta la integración del comercio con Openpay y las pruebas corridas contra el ambiente de pruebas con las llaves entregadas por correo. Cubre el recorrido completo de compra —catálogo, carrito, checkout, cobro con 3D Secure y alta de la suscripción recurrente—, las veintidós pruebas ejecutadas y los cuatro defectos que las pruebas destaparon, ya corregidos. Cierra con lo que no se puede cerrar de este lado porque depende de la configuración de la cuenta.

Resumen. El flujo de contratación funciona de extremo a extremo en sandbox: se cobró \$13,920.00 MXN por tres suscripciones, el banco confirmó por 3D Secure y quedaron dadas de alta las tres recurrencias con la fecha correcta del siguiente cargo. Las pruebas encontraron **cuatro defectos**, los cuatro ya corregidos —uno de ellos grave, porque mezclaba los expedientes de clientes distintos. Quedan **dos topes de la cuenta** que sólo Openpay puede levantar.



No.	Punto	Estado
1	Llaves y ambiente sandbox configurados	Probado
2	Planes de suscripción creados en el panel	Probado
3	Catálogo público con IVA desglosado y periodicidad	Probado
4	Carrito: agregar, cambiar cantidad, quitar, vaciar	Probado
5	Checkout con resumen previo a capturar la tarjeta	Probado
6	Tokenización en el navegador (el PAN no toca el servidor)	Probado
7	Cobro del primer periodo con 3D Secure	Probado
8	Alta de la suscripción recurrente tras el cobro	Probado
9	Idempotencia: recargar no duplica ni cobra dos veces	Probado
10	Tope de tres tarjetas guardadas por cliente	Probado
11	Mensajes de declinación saneados	Probado
12	Cancelación sin penalización	Probado
13	Cliente equivocado por el filtro de correo	Corregido
14	Variable de entorno vacía tumbaba el cobro	Corregido
15	Errores de operación mostrados como declinación	Corregido
16	La CSP habría bloqueado el antifraude al ponerla en vigor	Corregido
17	Tope de \$10,000 por plan (plan anual son \$11,600)	Con Openpay
18	Tope de \$84,295 por transacción	Con Openpay



1. Ambiente y configuración

Llaves

Las llaves del sandbox quedaron cargadas en variables de entorno, nunca en el código. La llave privada **no lleva** el prefijo NEXT_PUBLIC_, que es lo que la publicaría en el paquete que descarga el navegador. Se verificó sobre la compilación de producción:

- La llave privada sk_... **no aparece** en ningún archivo servido al navegador.
- El identificador de comercio y la llave pública pk_... sí aparecen, que es lo correcto: se necesitan para tokenizar del lado del cliente.
- NEXT_PUBLIC_OPENPAY_SANDBOX=true: el sitio apunta a sandbox-api.openpay.mx y el formulario muestra el aviso de ambiente de pruebas.

Planes dados de alta

Los dos planes se crearon por API en el panel del comercio:

Plan	Identificador	Importe
Vigilancia fiscal (mensual)	pougg6slphukzbr5rgry	\$1,160.00 / mes
Vigilancia fiscal · anual	pk1pbqzqj06hbt6kkxwc	\$10,000.00 / año

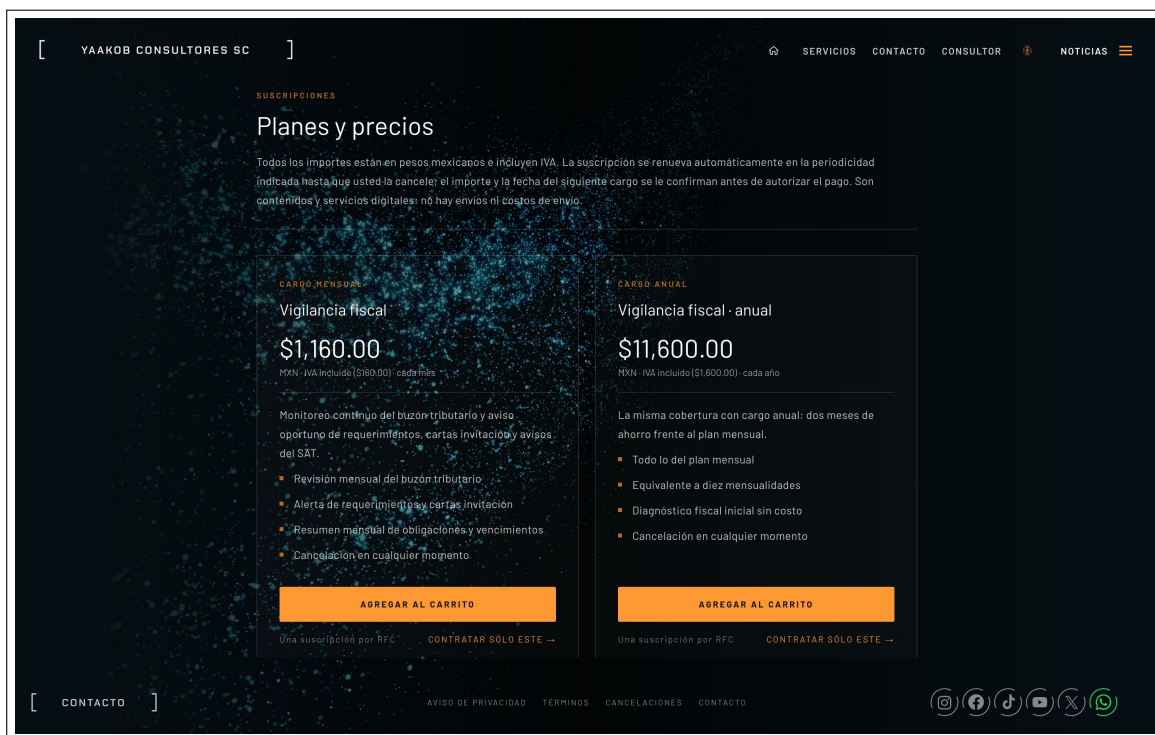
El plan anual no coincide con el precio publicado. La cuenta sandbox rechaza cualquier plan por encima de \$10,000.00 (error_code 1003), y el plan anual son \$11,600.00 con IVA. Quedó dado de alta en \$10,000.00 para poder probar el camino completo. **Antes de salir a producción hay que levantar ese tope y volver a crear el plan con el importe real.**



2. Recorrido de compra

2.1 Catálogo público

El catálogo es consultable sin registro previo. Cada plan publica el importe total en pesos, el IVA desglosado, la moneda y la periodicidad del cargo, y el encabezado advierte la renovación automática y que no hay envíos ni costos de envío por tratarse de un servicio digital.



Pantalla /planes: importe con IVA desglosado, periodicidad y condiciones de cancelación en cada tarjeta.

2.2 El carrito se alimenta desde el catálogo

Al agregar, la tarjeta confirma en pantalla lo acumulado y el indicador superior muestra el número de suscripciones y el total en vivo. El carrito admite conceptos distintos en la misma orden: el plan mensual y el anual conviven sin sustituirse.



The screenshot displays the 'Planes y precios' (Plans and prices) section of the Yaakob Consultores SC website. The page has a dark blue background with a subtle pattern. At the top, there is a navigation bar with the company name in brackets, a home icon, and links for 'SERVICIOS', 'CONTACTO', 'CONSULTOR', and 'NOTICIAS'. A shopping cart icon shows '3 CARRITO - \$13,920.00'. Below the navigation, the title 'Planes y precios' is followed by a disclaimer: 'Todos los importes están en pesos mexicanos e incluyen IVA. La suscripción se renueva automáticamente en la periodicidad indicada hasta que usted la cancele; el importe y la fecha del siguiente cargo se le confirman antes de autorizar el pago. Son contenidos y servicios digitales: no hay envíos ni costos de envío.' Two subscription plans are presented in white cards. The 'CARGO MENSUAL' (Monthly Charge) card lists 'Vigilancia fiscal' for \$1,160.00 (MXN - IVA incluido \$160.00 - cada mes) and includes services like tax mailbox monitoring, monthly reviews, alerts, and summaries. The 'CARGO ANUAL' (Annual Charge) card lists 'Vigilancia fiscal - anual' for \$11,600.00 (MXN - IVA incluido \$1,600.00 - cada año) and includes the same coverage as the monthly plan plus a free initial fiscal diagnosis. Both cards have an 'AGREGAR OTRA SUSCRIPCIÓN' button. At the bottom, a footer contains a 'CONTACTO' link in brackets, a row of links for 'AVISO DE PRIVACIDAD', 'TÉRMINOS', 'CANCELACIONES', and 'CONTACTO', and a row of social media icons for Instagram, Facebook, TikTok, YouTube, X, and WhatsApp.

[YAAKOB CONSULTORES SC]

SUSCRIPCIONES

3 CARRITO - \$13,920.00

Planes y precios

Todos los importes están en pesos mexicanos e incluyen IVA. La suscripción se renueva automáticamente en la periodicidad indicada hasta que usted la cancele; el importe y la fecha del siguiente cargo se le confirman antes de autorizar el pago. Son contenidos y servicios digitales: no hay envíos ni costos de envío.

CARGO MENSUAL

Vigilancia fiscal

\$1,160.00

MXN - IVA incluido (\$160.00) - cada mes

Monitoreo continuo del buzón tributario y aviso oportuno de requerimientos, cartas invitación y avisos del SAT:

- Revisión mensual del buzón tributario
- Alerta de requerimientos y cartas invitación
- Resumen mensual de obligaciones y vencimientos
- Cancelación en cualquier momento

AGREGAR OTRA SUSCRIPCIÓN

EN EL CARRITO (2) - VER CARRITO →

CARGO ANUAL

Vigilancia fiscal - anual

\$11,600.00

MXN - IVA incluido (\$1,600.00) - cada año

La misma cobertura con cargo anual: dos meses de ahorro frente al plan mensual.

- Todo lo del plan mensual
- Equivalente a diez mensualidades
- Diagnóstico fiscal inicial sin costo
- Cancelación en cualquier momento

AGREGAR OTRA SUSCRIPCIÓN

EN EL CARRITO (1) - VER CARRITO →

[CONTACTO]

AVISO DE PRIVACIDAD | TÉRMINOS | CANCELACIONES | CONTACTO

Instagram Facebook TikTok YouTube X WhatsApp

Dos suscripciones mensuales y una anual agregadas: el indicador muestra 3 y el total acumulado.



2.3 La orden se modifica antes de pagar

Cada renglón sube o baja de cantidad, se quita por separado o se vacía el carrito completo. Los totales —conceptos, suscripciones, subtotal, IVA al 16 % y total— se recalculan al instante. El envío aparece explícitamente como no aplicable por ser servicio digital.

[YAAKOB CONSULTORES SC]

SU CARRITO

Carrito de contratación

Revise y modifique lo que va a contratar antes de pagar. Los importes están en pesos mexicanos con IVA incluido; cada renglón renueva en su propia periodicidad hasta que usted lo cancele. Son servicios digitales: no hay envíos ni costos de envío.

CARGO MENSUAL	- 2 +	\$2,320.00
Vigilancia fiscal		IVA \$320.00 - cada mes
\$1,160.00 MXN - IVA incluido (\$1,600.00) - renueva cada mes		
Una suscripción por cada RFC bajo vigilancia		
CARGO ANUAL	- 1 +	\$11,600.00
Vigilancia fiscal - anual		IVA \$1,600.00 - cada año
\$11,600.00 MXN - IVA incluido (\$1,600.00) - renueva cada año		
Una suscripción por cada RFC bajo vigilancia		

TOTAL DE LA ORDEN	
Conceptos	2
Suscripciones	3
Subtotal	\$12,000.00
IVA (16 %)	\$1,920.00
Envío	No aplica - servicio digital

[CONTACTO]

AVISO DE PRIVACIDAD TERMINOS CANCELACIONES CONTACTO

Instagram Facebook Twitter YouTube WhatsApp

Pantalla /carrito: controles de cantidad, “Quitar” por renglón y totales recalculados.



2.4 Checkout: la orden completa antes de cualquier dato de pago

Antes de pedir un solo dato de la tarjeta se muestra, por renglón, el importe, el IVA incluido, la periodicidad de renovación y la fecha del siguiente cargo; al pie, el total a pagar hoy y las condiciones de cancelación. “Modificar el carrito” regresa sin perder lo capturado.

The screenshot shows a web interface for 'Yaakob Consultores SC' with a dark theme. The main heading is 'Contratar suscripción'. Below it, a box titled 'RESUMEN DE LA ORDEN' displays the following details:

RESUMEN DE LA ORDEN	
Vigilancia fiscal x 2	\$2,320.00
IVA incluido	\$320.00
Periodicidad	Renovación cada mes
Siguiente cargo	24 de septiembre de 2026
Vigilancia fiscal anual	\$11,600.00
IVA incluido	\$1,600.00
Periodicidad	Renovación cada año
Siguiente cargo	24 de agosto de 2027
Subtotal	\$12,000.00
IVA (16%)	\$1,920.00
Envío	No aplica - servicio digital
Cancelación	En cualquier momento, sin penalización
Total a pagar hoy	\$13,920.00 MXN

Below the summary, there is a link 'MODIFICAR EL CARRITO →'. The footer includes a 'CONTACTO' link, a row of links for 'AVISO DE PRIVACIDAD', 'TERMINOS', 'CANCELACIONES', and 'CONTACTO', and a row of social media icons (Instagram, Facebook, TikTok, YouTube, X, and WhatsApp).

Pantalla /suscripcion: resumen de la orden con fecha del siguiente cargo por cada plan.



2.5 Formulario y método de pago

El número de tarjeta se tokeniza en el navegador contra Openpay: **no viaja ni se almacena en los servidores de Yaakob**. El botón confirma el importe exacto de la operación y el texto debajo advierte la renovación de cada suscripción, la cancelación sin penalización y la confirmación por 3D Secure. Al pie van las marcas aceptadas y la leyenda “Procesado por Openpay”.

[YAAKOB CONSULTORES SC]

Subtotal	\$12,000.00
IVA (16 %)	\$1,920.00
Envío	No aplica - servicio digital
Cancelación	En cualquier momento, sin penalización
Total a pagar hoy	\$13,920.00 MXN

SERVICIOS CONTACTO CONSULTOR NOTICIAS

MODIFICAR EL CARRITO

Ambiente de pruebas (sandbox). No se realizan cobros reales.

DATOS DEL TITULAR

NOMBRE: Diana APELLIDOS: Ruiz Salazar

CORREO ELECTRÓNICO: diana.ruiz@ejemplo.com TELÉFONO: 5555555555

DATOS DE LA TARJETA

NOMBRE COMO APARECE EN LA TARJETA: DIANA RUIZ SALAZAR

NÚMERO DE TARJETA: 4111 1111 1111 1111

MES: 12 AÑO: 29 CVV: ...

[CONTACTO]

AVISO DE PRIVACIDAD TÉRMINOS CANCELACIONES CONTACTO

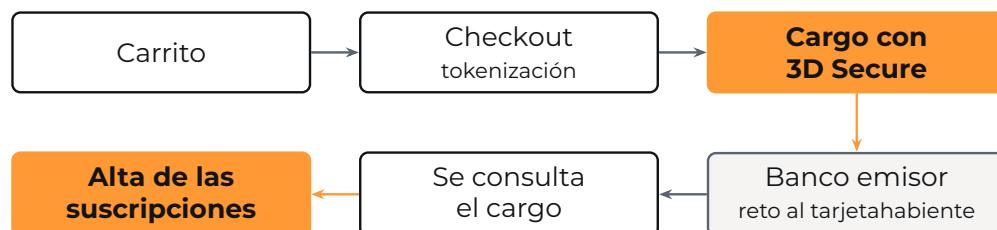
Instagram Facebook TikTok YouTube X WhatsApp

Formulario con el aviso de ambiente de pruebas, datos del titular y datos de la tarjeta.



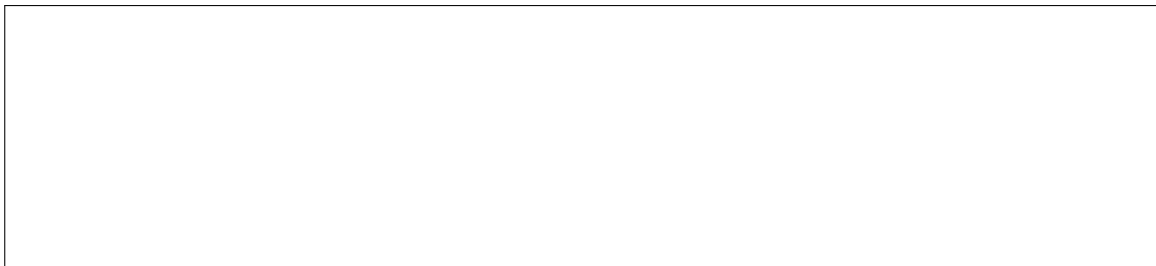
3. Cobro, 3D Secure y alta de la suscripción

El orden de las operaciones no es casual. La suscripción **no** se crea al enviar el formulario: mientras 3D Secure no termine no hay dinero confirmado, y una suscripción activa sin primer cobro es una aclaración segura. Sólo cuando el cargo se consulta a Openpay y responde `completed` se dan de alta las recurrencias, con `trial_end_date` al final del periodo ya pagado para que el cobro automático no duplique el primer mes.



El estado del pago se lee de Openpay, nunca de la URL de retorno. El banco devuelve al usuario con parámetros en la dirección, y cualquiera puede escribir esos parámetros a mano. Sólo el cargo consultado a la API abre el acceso.

3.1 El reto del banco

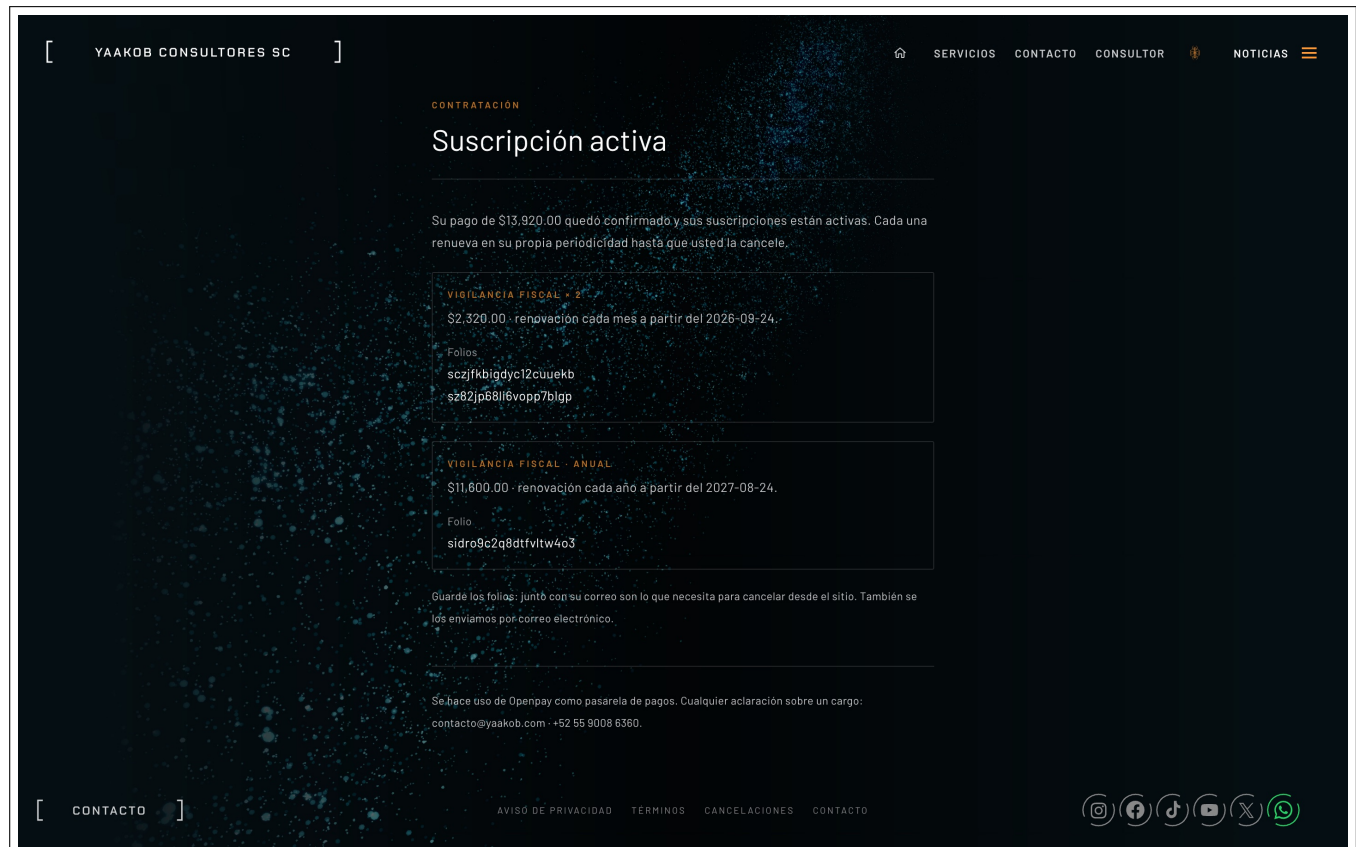


Simulador 3D Secure v2 del sandbox: comercio, terminación de la tarjeta e importe de la operación.



3.2 Suscripciones activas

Al volver del banco, la pantalla de resultado confirma el cargo y las suscripciones dadas de alta, cada una con su periodicidad y la fecha de su próximo cargo.



Pantalla /suscripcion/resultado: cargo confirmado y suscripciones activas.

Verificado del lado de Openpay, sobre el cliente de la operación:

Suscripción	Plan	Siguiente cargo
sj2uvp7mmchubw5ovrse	Vigilancia fiscal	25/09/2026
s6lhp4t0jmgmynxvu6ed	Vigilancia fiscal	25/09/2026
sxeov8tscjjz103s6ief	Vigilancia fiscal · anual	25/08/2027

3.3 Cancelación

La cancelación no obliga a llamar por teléfono. Como el sitio todavía no tiene cuentas de usuario, la autorización es por capacidad: hacen falta **a la vez** el folio de la suscripción —un valor opaco de Openpay que sólo conoce quien completó la contratación— y el correo con el que se contrató, contra el que se verifica que la suscripción efectivamente le pertenece.



[YAAKOB CONSULTORES SC]

[SERVICIOS](#) [CONTACTO](#) [CONSULTOR](#) [NOTICIAS](#)

SUSCRIPCIONES

Cancelar suscripción

La cancelación surte efecto de inmediato para los cobros futuros. Conserva el acceso hasta el final del periodo que ya pagó. No necesita darnos una explicación.

CORREO CON EL QUE CONTRATÓ

FOLIO DE LA SUSCRIPCIÓN

CANCELAR MI SUSCRIPCIÓN

¿No encuentra su folio? Escribanos a contacto@yaakob.com desde el correo con el que contrató, o llame al +52 55 9008 6360 de lunes a viernes de 9:00 a 18:00 h. También cancelamos por esa vía.

[VER LA POLÍTICA COMPLETA](#)

[CONTACTO]

[AVISO DE PRIVACIDAD](#) [TÉRMINOS](#) [CANCELACIONES](#) [CONTACTO](#)

Pantalla /suscripcion/cancelar.



4. Pruebas ejecutadas

Veintidós pruebas contra el sandbox. Las que debían fallar, fallaron; y fallaron con el mensaje correcto, que es la mitad del trabajo.

4.1 Camino feliz

#	Prueba	Resultado
1	Contratación de 3 suscripciones por \$13,920.00 con 3D Secure	Probado
2	Retorno del banco a la pantalla de resultado	Probado
3	Alta de las 3 recurrencias con la fecha correcta	Probado
4	Repetir la confirmación no crea suscripciones nuevas	Probado
5	Contratación de un solo plan mensual, extremo a extremo	Probado

4.2 Lo que debe rechazarse

#	Prueba	Resultado
6	Referencia ya cobrada: Openpay la rechaza (1006)	Probado
7	Reintento tras una declinación: sí se permite	Probado
8	Cantidad fuera de rango (999)	Probado
9	Plan inexistente	Probado
10	El mismo plan repetido en dos renglones	Probado
11	Falta el identificador antifraude	Probado
12	Referencia con formato inválido	Probado
13	GET a la ruta de cobro: 405	Probado
14	Importe por encima del tope del comercio	Probado
15	Cuarta tarjeta con tres ya guardadas: 409	Probado
16	Tarjeta declinada por el emisor: mensaje saneado	Probado
17	La tarjeta que no cobró se retira del cliente	Probado

4.3 Cancelación y datos del cliente

#	Prueba	Resultado
18	Folio válido con un correo ajeno: rechazado	Probado
19	Correo correcto con folio inventado: rechazado	Probado
20	Folio y correo correctos: cancela	Probado
21	Cancelar dos veces el mismo folio: rechazado	Probado
22	Cada cliente nuevo queda en su propio expediente	Probado

Tarjetas usadas: 4111 1111 1111 1111 (aprobada), 5555 5555 5555 4444 y 5105 1051 0510 5100 (aprobadas, para el tope de tarjetas) y 4000 0000 0000 0002 (declinada por el emisor, error_code 3001).



5. Defectos que destaparon las pruebas

5.1 Cada cliente nuevo se colgaba del expediente de otro

Corregido. Openpay acepta el parámetro `email` en `GET /customers` pero **no filtra por él**: devuelve la lista completa de clientes del comercio. El código se quedaba con el primer renglón de esa lista, de modo que la tarjeta, el cargo y la suscripción de cada suscriptor nuevo terminaban en el expediente de otra persona.

Es el hallazgo grave de esta ronda. Además del cruce de datos, la ruta de cancelación verificaba la propiedad del folio contra la lista de un cliente ajeno: es decir, no verificaba nada.

Ahora se recorren las páginas de clientes y se compara el correo contra lo que trae cada registro. Verificado: cuatro contrataciones seguidas con correos distintos quedaron en cuatro expedientes distintos.

5.2 Una variable de entorno vacía tumbaba todo cobro

Corregido. El archivo de ejemplo declara `OPENPAY_MERCHANT_ID=` sin valor. En JavaScript el operador `??` sólo cae al valor de respaldo cuando lo que tiene enfrente es nulo, y una cadena vacía no lo es: el comercio se quedaba sin identificador y **cada cobro moría** con un error de servidor disfrazado de “Tarjeta declinada”. El mismo patrón afectaba la dirección de retorno de 3D Secure. Ambos usan ahora el operador correcto.

5.3 Errores de operación presentados como declinación

Corregido. Dos códigos de Openpay caían en el mensaje genérico y mandaban al cliente a hablar con su banco por algo que su banco no puede resolver:

Código	Mensaje que ve ahora el cliente
1006	Esta operación ya se procesó. Revise su correo antes de intentar de nuevo.
1012	El importe supera el máximo por operación. Divida la orden o escríbanos.

5.4 La política de seguridad habría bloqueado el antifraude

Corregido. La `Content-Security-Policy` del sitio corre en modo reporte, y durante el cobro reportó dos violaciones: el antifraude de Openpay —`openpay-data.v1.min.js`— no se queda en dominios de Openpay, sino que monta marcos de Kount y de OpenControl para calcular el `device_session_id`. Con la política en modo reporte los marcos cargan igual, pero **el día que se ponga en bloqueo el antifraude habría dejado de funcionar** y los cargos se habrían quedado sin huella de dispositivo. Los dominios ya están declarados.

El resto de los motivos de declinación del emisor se sigue mostrando como “Tarjeta declinada”. Openpay pide expresamente que “fondos insuficientes” y “tarjeta reportada como perdida o robada” no lleguen al tarjetahabiente; aquí la regla se aplicó a **todos** los motivos del emisor, no sólo a esos dos: el navegador nunca recibe el texto crudo de Openpay.



6. Lo que depende de Openpay

6.1 Tope de \$10,000 por plan

Con Openpay. El plan anual son \$11,600.00 con IVA y la cuenta no acepta darlo de alta. Solicitamos que se levante el tope para poder crear el plan con su importe real.

6.2 Tope de \$84,295 por transacción

Con Openpay. El carrito admite hasta veinte suscripciones por operación, que rebasan ese tope sin esfuerzo. Hoy el cliente recibe un mensaje claro pidiéndole dividir la orden, pero conviene saber cuál es el tope definitivo en producción para ajustar el máximo del carrito a un número que sí se pueda cobrar.

7. Lo que falta de nuestro lado

- **Correo transaccional.** La pantalla de resultado ofrece enviar el folio por correo y hoy ese correo no sale. Hay que conectar un proveedor o retirar la frase antes de la cita.
- **Webhook de Openpay.** Los cobros recurrentes posteriores al primero ocurren del lado de Openpay; sin webhook el sitio no se entera de un cargo fallido ni de una suscripción vencida. Para la validación no es obligatorio; para operar, sí.
- **Cuentas de usuario.** Sin sesión no puede haber un área donde el suscriptor administre sus tarjetas guardadas. Deliberadamente **no** se construyó un endpoint que liste tarjetas o suscripciones a partir de un correo: sin autenticación eso es una fuga de datos de clientes, no una funcionalidad.